

CO4-ASSESSMENT TOOL - 3

ITA1407 - Ethical Hacking

NAME: RISHIVARTHINI S

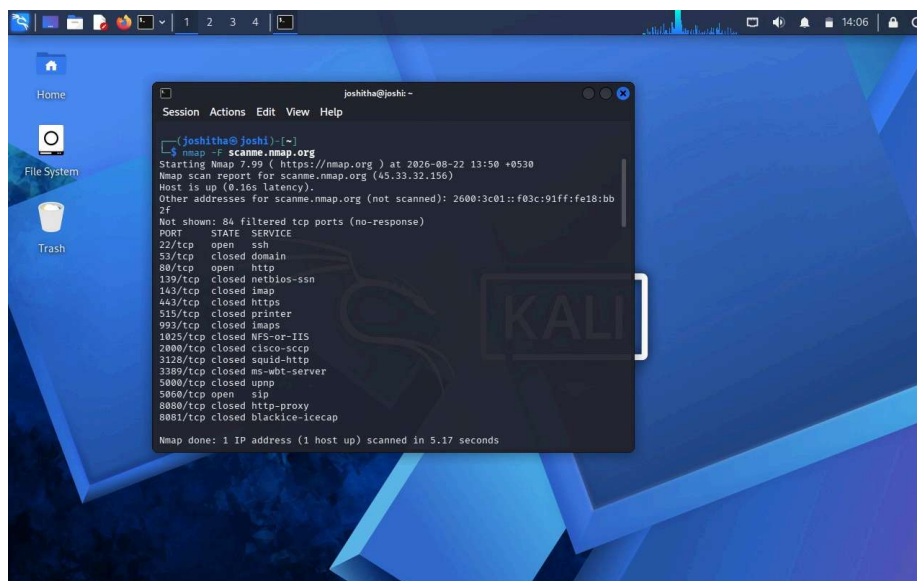
REG NO: 192421291

1. A mid-sized e-commerce company hosts its web application on an Apache server running on a Linux environment. Recently, customers reported unauthorized transactions and abnormal account activities. Upon investigation, the IT team discovered suspicious HTTP requests in server logs, including attempts to access hidden directories and injection of malicious scripts into input fields. Additionally, the server is running an outdated version with known vulnerabilities, and no Web Application Firewall (WAF) is implemented. As a cybersecurity analyst, you are tasked with conducting a comprehensive security assessment using Kali Linux. Analyze the possible attack vectors exploited by the attacker, including web server vulnerabilities, input validation issues, and outdated software components. Explain in detail how you would perform reconnaissance, vulnerability scanning, and exploitation using appropriate Kali Linux tools. Further, propose a layered defense strategy that includes server hardening, secure coding practices, and network-level protections to prevent such incidents in the future.

KaliLinux Commands:

`nmap -F scanme.nmap.org`

Output:



```
joshitha@joshitha:~$ nmap -F scanme.nmap.org
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-22 13:50 +0530
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.165 latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb
2f
Not shown: 84 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    closed domain
80/tcp    open  http
139/tcp   closed netbios-ssn
143/tcp   closed imap
443/tcp   closed https
515/tcp   closed printer
993/tcp   closed imaps
1025/tcp  closed NFS-or-IIIS
2000/tcp  closed cisco-scp
3128/tcp  closed squid-http
3389/tcp  closed ms-wbt-server
5000/tcp  closed upnp
5800/tcp  open  sip
8080/tcp  closed http-proxy
8081/tcp  closed blackice-icecap

Nmap done: 1 IP address (1 host up) scanned in 5.17 seconds
```

2. A financial services web application allows users to log in, view account details, and perform transactions. A recent penetration test revealed that the application is vulnerable to SQL injection and Cross-Site Scripting (XSS) attacks. Error messages expose database structure information, and user inputs are not properly sanitized. Attackers have exploited these weaknesses to extract sensitive customer data and inject malicious scripts into web pages viewed by other users. You are assigned to perform a detailed security audit of the application. Question: Examine how SQL injection and XSS vulnerabilities can be exploited in this scenario. Describe a step-by-step methodology using Kali

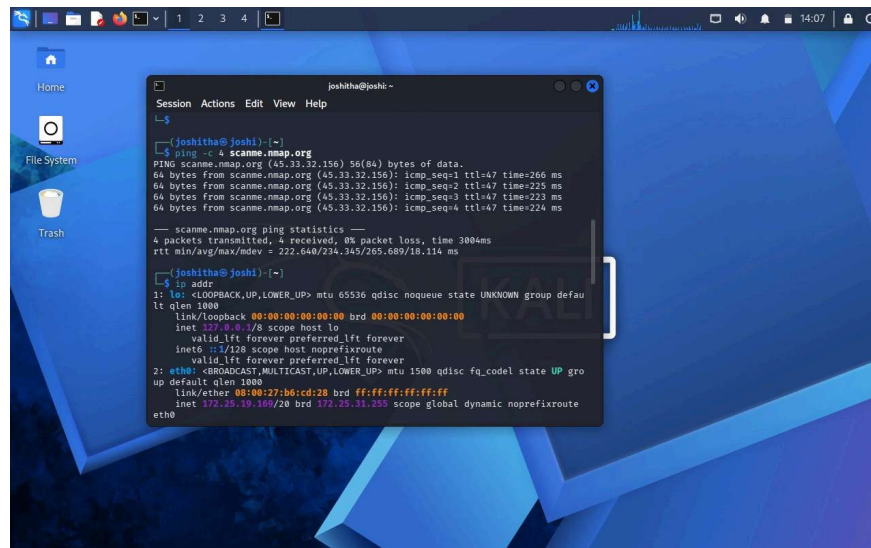
Linux tools such as Burp Suite and SQLmap to identify and validate these vulnerabilities. Evaluate the impact of such attacks on confidentiality, integrity, and availability (CIA triad). Recommend comprehensive mitigation strategies, including input validation, output encoding, secure session handling, and implementation of security controls.

KaliLinux Commands:

ping -c 4 scanme.nmap.org

ip addr

Output:

A screenshot of a Kali Linux desktop environment. The desktop background is a blue and purple geometric pattern. On the left side, there are icons for 'Home', 'File System', and 'Trash'. A terminal window titled 'joshitha@joshitha' is open in the center. The terminal shows the following commands and their outputs:

```
joshitha@joshitha:~$ ping -c 4 scanme.nmap.org
PING scanme.nmap.org (45.33.32.156) 56(84) bytes of data:
64 bytes from scanme.nmap.org (45.33.32.156): icmp_seq=1 ttl=47 time=266 ms
64 bytes from scanme.nmap.org (45.33.32.156): icmp_seq=2 ttl=47 time=225 ms
64 bytes from scanme.nmap.org (45.33.32.156): icmp_seq=3 ttl=47 time=223 ms
64 bytes from scanme.nmap.org (45.33.32.156): icmp_seq=4 ttl=47 time=224 ms

--- scanme.nmap.org ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 222.648/234.345/265.689/18.114 ms

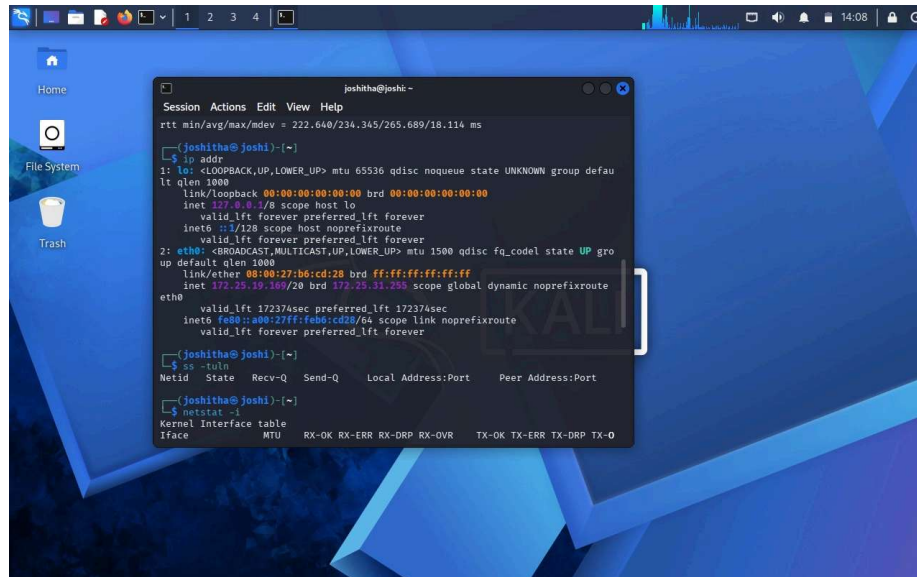
joshitha@joshitha:~$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:b6:cd:28 brd ff:ff:ff:ff:ff:ff
    inet 172.25.19.160/20 brd 172.25.31.255 scope global dynamic noprefixroute
    eth0
```

3. A corporate office provides wireless internet access to employees using WPA2-PSK authentication. Recently, several employees reported unusual login prompts and slow network performance. security investigation revealed the presence of a rogue access point (Evil Twin) mimicking the official network SSID. Attackers used this setup to capture login credentials and perform man-in-the-middle (MITM) attacks. You are tasked with analyzing the breach and strengthening wireless security. Explain how the attacker successfully executed the Evil Twin attack and intercepted sensitive data. Describe how Kali Linux tools such as Aircrack-ng and Wireshark can be used to detect and analyze such attacks. Evaluate the weaknesses in the existing wireless security configuration. Propose robust countermeasures, including secure authentication mechanisms, network monitoring, and user awareness strategies.

KaliLinux Commands:

netstat -i

Output:

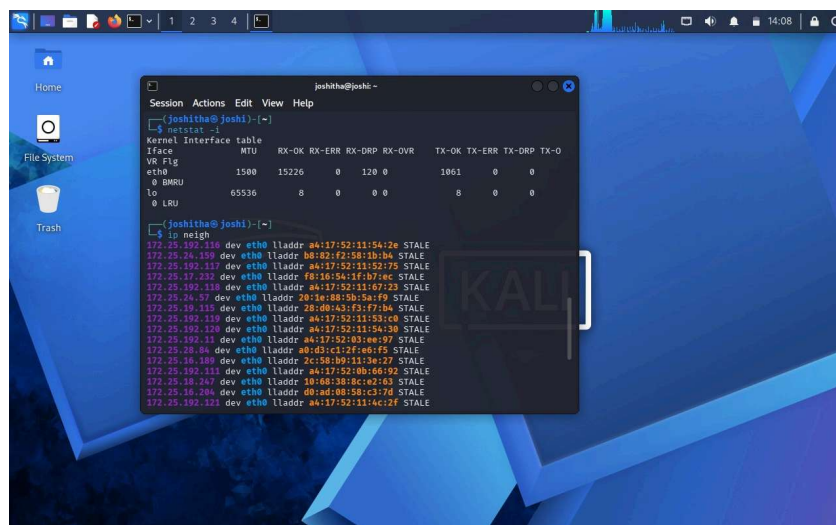


4. An organization's internal network hosts a web-based employee management system accessible over Wi-Fi. The wireless network uses weak passwords, and the web application lacks proper authentication and session management. An attacker gains access to the Wi-Fi network, performs reconnaissance, and exploits vulnerabilities in the web application to escalate privileges and access confidential employee data. You are assigned to perform a full penetration testing assessment. Analyze the attack chain starting from wireless network compromise to web application exploitation. Describe each phase of the attack, including reconnaissance, scanning, exploitation, and privilege escalation. Demonstrate how Kali Linux tools can be used in each phase. Propose a comprehensive security framework that addresses both wireless and web application vulnerabilities, ensuring Defense-in-depth.

KaliLinux Commands:

```
netstat -i
```

Output:

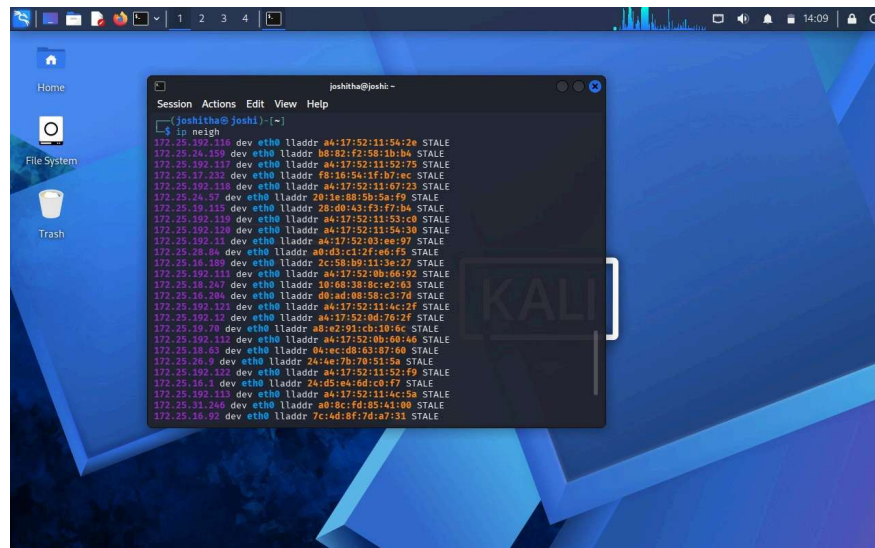


5. A university campus experiences frequent Wi-Fi disruptions during peak hours. Investigation reveals repeated deauthentication attacks targeting access points, causing legitimate users to disconnect. The attacker uses automated tools to continuously send death packets, leading to denial of service. You are tasked with identifying the cause and implementing solutions. Explain how deauthentication attacks are carried out in wireless networks and how attackers exploit protocol weaknesses. Describe how Kali Linux tools can be used to simulate and analyze such attacks in a controlled environment. Evaluate the impact on network availability and user productivity. Recommend effective mitigation strategies, including network configuration changes, intrusion detection systems, and secure wireless protocols.

KaliLinux Commands:

`ip neigh`

Output:



```
joshitha@josh: ~  
Session Actions Edit View Help  
joshitha@josh:~$ ip neigh  
172.25.192.118 dev eth0 lladdr aa:17:52:11:56:26 STALE  
172.25.24.155 dev eth0 lladdr b8:80:f2:58:1b:b4 STALE  
172.25.192.117 dev eth0 lladdr aa:17:52:11:52:79 STALE  
172.25.17.232 dev eth0 lladdr f8:16:54:1f:b7:ec STALE  
172.25.192.116 dev eth0 lladdr aa:17:52:11:47:23 STALE  
172.25.24.57 dev eth0 lladdr 28:1e:88:5b:5a:f9 STALE  
172.25.19.115 dev eth0 lladdr 28:d0:43:f3:f7:b4 STALE  
172.25.192.118 dev eth0 lladdr aa:17:52:11:52:1c STALE  
172.25.192.120 dev eth0 lladdr aa:17:52:11:54:30 STALE  
172.25.192.11 dev eth0 lladdr aa:17:52:03:ee:97 STALE  
172.25.24.84 dev eth0 lladdr a0:d3:c2:2f:e6:f5 STALE  
172.25.16.188 dev eth0 lladdr 2c:5b:b9:11:3e:27 STALE  
172.25.192.131 dev eth0 lladdr aa:17:52:0b:66:92 STALE  
172.25.18.247 dev eth0 lladdr 18:a0:38:8c:e2:63 STALE  
172.25.16.204 dev eth0 lladdr d0:nd:00:5b:c3:7d STALE  
172.25.192.121 dev eth0 lladdr aa:17:52:11:4c:2f STALE  
172.25.192.12 dev eth0 lladdr aa:17:52:0d:76:2f STALE  
172.25.19.78 dev eth0 lladdr a6:e2:91:cb:10:6c STALE  
172.25.192.132 dev eth0 lladdr aa:17:52:0b:60:46 STALE  
172.25.18.63 dev eth0 lladdr 04:ec:08:63:87:60 STALE  
172.25.26.9 dev eth0 lladdr 24:4e:7b:70:51:5b STALE  
172.25.192.122 dev eth0 lladdr aa:17:52:11:52:f9 STALE  
172.25.16.1 dev eth0 lladdr 24:d5:e4:6d:c8:f7 STALE  
172.25.192.113 dev eth0 lladdr aa:17:52:11:4c:5a STALE  
172.25.31.246 dev eth0 lladdr a0:8c:fd:85:41:00 STALE  
172.25.16.92 dev eth0 lladdr 7c:4d:8f:7d:a7:11 STALE
```